中心化交易所提币授权的抗合谋与抗胁迫机制研究

基于独立用户意图与全路径资产约束的设计框架

Koji Tamaki
独立研究者
kojitamaki223@gmail.com · https://github.com/mavis-codee

2026 年 11 月 9 日 · 版本 1.0

摘要

中心化交易所的资产托管同时依赖密码学签名与组织内部的授权过程。密钥未被导出、交易签名能够通过链上验证，并不足以证明资产转移符合客户真实意愿。本文研究员工被收买、签名托管人员受胁迫以及管理层受胁迫时的授权安全，以 2026 年币安安全事件的公开资料为背景，区分密钥保密、消息授权与资产退出三个边界。本文提出一种概念性框架，将独立用户意图、可验证权益账本、单次执行状态与不可绕过的资产守卫结合，并将管理、恢复和资金调拨纳入同一安全边界。在用户授权根与资产执行规则未失陷等明确假设下，该框架旨在使交易所内部人员即使合谋或受胁迫，也无法单凭平台权限完成未经授权的资产转移。本文给出条件性安全命题及证明概要，并以包含 112 个配置和 8,496 次迁移尝试的有界模型检验展示关键约束的作用及移除约束后的反例。结果仅适用于本文的抽象状态模型，不构成生产协议安全证明、真实交易所审计或实际部署结果。

关键词：中心化交易所；托管安全；提币授权；内部人员威胁；胁迫；信任边界

Abstract

Cryptographic key protection does not by itself establish that a custodial transfer reflects a customer's authorized intent. This paper examines withdrawal authorization when employees are bribed, signing custodians are coerced, or exchange management is compelled to cooperate with an attacker. Using public accounts of the 2026 Binance incident as motivation, it distinguishes key confidentiality, message authorization, and asset execution. A conceptual framework combines independent customer intent, a verifiable entitlement ledger, single-use execution state, and an asset guard that cannot be bypassed by ordinary signing or administrative authority. Management, recovery, and treasury movements are included in the protected boundary. Conditional safety arguments explain when unauthorized transfers remain blocked despite compromise of exchange-controlled roles. A bounded abstract model explores 112 configurations and 8,496 transition attempts, with control-removal variants exposing counterexamples. These results concern a small authorization state machine. They are not a production implementation, an audit of an exchange, or a general cryptographic security proof. The framework reduces reliance on exchange personnel while retaining explicit assumptions about customer authorization, ledger correctness, execution integrity, and blockchain security.

Keywords: custodial exchange; withdrawal authorization; insider threat; coercion; collusion; trust boundaries

1 引言

交易所提币通常包含用户申请、平台审核、待签交易构建、平台钱包签名、交易广播及链上确认。链上验证可以确认交易满足资产的花费条件，却不会自动确认交易所内部某位客户是否同意该笔资产转移。由此，平台内部形成的业务授权与链上认可的花费权限之间存在需要单独保护的边界。

本文关注三类具体情形。第一，内部人员接受利益诱导，主动利用自身权限配合盗取资产。第二，负责签名设备、密钥份额或恢复材料的人员遭受暴力胁迫，被迫执行攻击者指令。第三，交易所所有者或管理层受威胁，通过现有管理权限要求系统放行资金转移。三类情形不要求签名算法被破解；攻击者可以尝试让正常的签名设施为非正常业务目的工作。

本文的研究问题是，当交易所内部身份不再代表可信行为时，哪些可验证约束仍能阻止未经客户授权的资产转移。所要建立的安全性质是资产转移授权完整性，而非判断人员是否诚实、推测其心理状态或保证任何情况下都能正常营业。人员停工、签名拒绝与资产被盗是不同结果，应分别处理。

本文贡献限于三个方面。其一，将贿赂、胁迫与设备失陷统一表达为授权主体被攻击者控制，并明确单点失陷与签名法定人数失陷的差别。其二，给出覆盖客户授权、权益账本、实际花费规则以及管理恢复路径的概念性约束框架。其三，提供独立观察支付效果的有界检验程序和控制移除反例，说明仅加强某一环节并不足以建立端到端安全。本文不主张首次发现托管信任风险，也不将信任依赖称为交易所的唯一漏洞。

2 事件背景与相关工作

2.1 公开事件资料的证据边界

币安 2026 年 11 月 3 日的初步报告将 10 月 29 日事件的受影响资产估计为约 63.4 亿美元，并描述了员工设备失陷、内部凭证被利用及钱包签名服务被未经授权使用的过程。报告注明调查仍在进行，相关结论需要进一步独立复核[1]。其 10 月 30 日更新称，当时未发现钱包私钥泄露的证据[2]。这不等于证明密钥从未泄露，也不等于签名权限没有被滥用。

TRM 的跨链分析认为，多种钱包在相近时间产生攻击者所需的有效签名，与签名基础设施失陷的解释相符[3]。FBI 将事件归因于 TraderTraitor，但其公开通报并未证明交易所员工主动参与犯罪[4]。本文将该事件作为研究动机，不以链上有效签名判断内部操作者身份，也不声称所提框架一定能够阻止该次攻击。

欧易当前公开说明包含风控检查、半离线多重签名、异地密钥与多人访问控制[5]。这些内容可用于识别托管系统需要讨论的控制层次，不能替代对其真实实现、签名阈值或独立执行边界的审计。本文不对欧易存在可利用漏洞或内部作恶作出认定。

2.2 签名安全与业务授权

门限签名可以分散签名权，但其密码学安全依赖相应的参与者失陷边界。例如，RFC 9591 对 FROST 的讨论包含密钥份额安全配置及被腐化参与者数量受限等假设[6]。本文引用该协议说明门限安全具有前提，不将 FROST 视为所有交易所使用的实现，也不将门限参数直接等同于独立组织或独立管理权限。

Saltzer 与 Schroeder 提出的完全仲裁、最小权限和权限分离原则，为每次敏感访问设置独立检查提供了基础[7]。NIST 的安全控制与密钥管理文献同样分别讨论组织控制和密钥材料生命周期[8-9]。这些工作提示，密钥保管与授权判断应作为不同层次分析。本文将这一分层用于提币、管理变更和恢复路径的一致性要求。

2.3 已有提款意图研究与本文范围

Syed 等人的预印本 IWAP 已直接研究后端失陷时的提款授权，提出在签名前独立核验客户意图、交易效果和单次支出预留，并明确其实现属于合成模型而非真实交易所基础设施[10]。本文承认与其研究问题的重合，不将独立意图绑定作为原创密码学发现。

本文的分析侧重受胁迫的内部签名法定人数、管理层以及恢复权限。它进一步区分两种部署路径：依赖至少一个诚实检查者的签名前控制，以及由资产自身花费条件强制执行的守卫。后者旨在将平台人员的全部签名能力与客户资产的任意退出能力分离。这里提出的是架构要求与抽象模型，不是一个已经完成实现的新密码学协议。

Provisions 等偿付能力证明工作研究交易所储备与客户负债的可验证关系[11]。储备证明回答的主要问题与某笔提款是否获得正确授权不同。本文还需要比一次总额快照更具体的条件：平台不能通过伪造客户余额、密钥登记或交易状态，为攻击者制造可被守卫接受的提款权益。

3 系统模型与威胁假设

3.1 主体与权限

系统包含客户及其独立授权终端 U、交易所业务后端 B、平台签名参与者集合 S、治理主体 M、恢复主体 R、权益账本 L，以及资产执行守卫 G。业务后端可以构建交易、安排队列和中继消息；这些能力不应自动包含伪造客户授权或修改客户权益的能力。

独立用户意图要求客户授权密钥或等效授权根不由交易所单方面保管、替换或重置。仅由交易所服务器确认的登录状态、短信验证码和数据库中的“用户同意”标记，不满足本文对平台完全失陷时的独立性要求。授权密钥初次登记及后续变更也必须取得可独立验证的客户同意。

权益账本 L 记录客户经过充值、交易、费用及提款后的可提权益。本文将其正确性明确列为安全假设与部署义务。平台签名或一棵由平台任意重建的 Merkle 树，不能单独证明账本中的资金归属真实。若平台能够凭空增加攻击者余额，即使攻击者使用自己的真实密钥，也可能取得形式完整但经济上不合法的提款。

3.2 攻击者能力

攻击者可以控制业务后端和网络中继，获取内部凭证，向签名设施提交自选消息，并可通过利益交换或胁迫控制部分内部主体。在强威胁情形中，交易所管理层和全部平台签名参与者都可以被控制。是否自愿不影响模型中的技术能力，身份高低也不提供额外安全保证。

本文区分以下情形，且不为其赋予现实发生概率。

威胁情形	被控制的能力	所需安全约束
内部人员被收买	利用合法身份提交或批准恶意请求	客户授权不能由该身份替代
托管人员受胁迫	按攻击者指令调用设备或使用密钥份额	单个托管权限不足以完成越权支出
管理层受胁迫	要求修改规则或触发应急操作	治理和恢复不能成为绕过路径
签名法定人数失陷	生成平台密钥认可的有效签名	资产花费仍需独立条件

表 1 内部贿赂与胁迫情形的能力映射

3.3 保留的假设

安全讨论保留以下前提。A1：客户授权根未失陷，登记与轮换不能由平台单方面替换。A2：签名和哈希等基础密码学原语满足预期性质。A3：L 的状态转移及客户权益证明真实有效。A4：G 的执行正确，所有受保护资产的退出均受其约束。A5：普通治理、升级与恢复不能取消 A1、A3 或 A4。A6：相应区块链执行与确认假设成立。本文不通过“代码不会说谎”省略这些前提。

客户本人遭受胁迫、授权终端展示内容被篡改、资产发行方冻结或任意扣划、链级共识失陷，以及未受 G 约束的资产，不属于本文强安全命题的覆盖范围。涉及这些能力时，应另行建立模型，不得沿用本文结论。

4 安全目标与能力边界

4.1 提款意图的完整绑定

将提款意图表示为式（1）。domain 是协议域标识，c 为链标识，v 为守卫地址或唯一资产容器标识，u 为客户授权身份，a 为资产标识，q 为金额，d 为接收地址，n 为单次序号，e 为有效期限，p 为客户接受的策略版本。资产标识必须消除同名代币歧义，金额必须使用确定的最小单位编码。

$$x = (\mathrm{domain}, c, v, u, a, q, d, n, e, p) \tag{1}$$

客户授权应绑定规范化后的完整字段。平台不能以某个页面上的地址或人工工单替代签名所覆盖的实际对象。手续费上限、允许的附加效果以及代币特殊行为，需由具体链适配器进一步绑定；无法界定效果的任意合约调用默认不属于普通提款。

4.2 安全性与可用性

目标 P1 为授权完整性，资产转移必须与独立客户授权一致。P2 为权益约束，提款不能超出该客户的真实可提权益。P3 为单次执行，同一意图不得重复支出。P4 为全路径约束，治理、恢复与资金调拨不得产生不受约束的资产出口。

可用性目标另行定义。拒绝提供服务、阻断证明数据或停止中继，可能阻止正常提款，但不会自动构成资产盗取。本文允许在无法满足验证条件时拒绝支出，不宣称在所有内部人员受胁迫或链拥堵时仍能持续完成提款。独立退出功能还需要可用的权益数据、证明生成能力及链上提交能力。

4.3 单纯提高签名人数的边界

设签名门限为 t，被攻击者控制的签名参与者数量为 f。依靠诚实签名参与者拒绝越权消息时，至少需要 f 小于 t，并且每一个可用签名法定人数都包含真正独立执行检查的诚实主体。式（2）表达这一必要结构条件，其中 H 为诚实检查者集合。

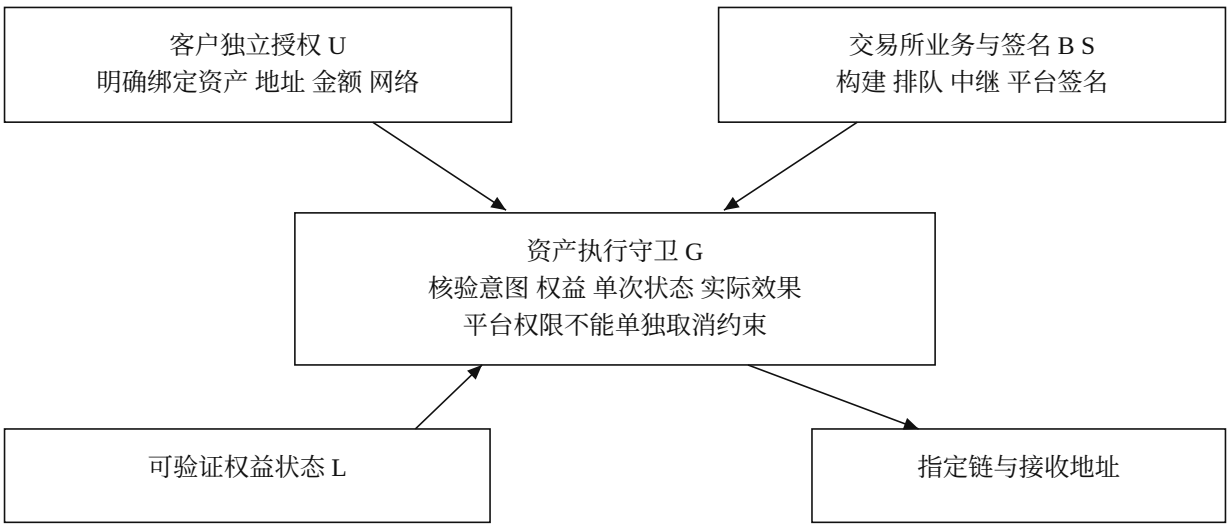
$$\forall\, Q \subseteq S,\ |Q| \geq t \Rightarrow Q \cap H \neq \varnothing \tag{2}$$

同一管理员控制多台设备、同一被入侵服务给多个签名人提供相同错误数据，以及恢复材料集中在同一控制域，都可能破坏其实际独立性。该条件不是完整的协议安全证明。若 f 达到 t，普通密钥直接控制的账户通常不能仅靠原有门限继续约束这组主体。

5 独立意图与全路径资产守卫框架

5.1 两层授权与资产出口

第一层是业务与运营授权，用于排队、合规检查、费用计算和中继。第二层是资产执行授权，由 G 强制检查客户意图、权益证明及单次状态。平台签名可用于运营操作，但不能独自替代第二层。图 1 给出逻辑边界，而非任何交易所的真实服务拓扑。



治理 恢复 与资金调拨必须保持同一资产边界

图 1 独立客户授权与不可绕过的资产执行边界

强部署要求资产实际存放在受 G 约束的容器内，或其原生花费条件具有等价约束。只在普通外部账户的签名前加入一个软件检查器，不能保护该账户免受全部签名法定人数合谋：他们仍可能绕开检查器另行签名。链上守卫、受限脚本或其他等价机制必须决定资产是否能够退出，而不是只向平台提供一个可被忽略的建议。

5.2 接受条件与执行顺序

式（3）概括概念性接受条件。V_U 验证客户授权及登记根，V_L 验证当前权益与状态转移，Fresh 检查序号、有效期及域绑定，Effects 检查实际资产效果与客户意图一致，Preserve 检查不变式及所有出口约束仍然保持。

$$\begin{aligned}\mathrm{Accept}(x,s) = {} & V_U(x) \wedge V_L(x,s) \wedge \mathrm{Fresh}(x,s) \\ & \wedge \mathrm{Effects}(x) \wedge \mathrm{Preserve}(s,x)\end{aligned} \tag{3}$$

执行顺序为：读取已确认状态，验证完整意图与权益，原子地消耗单次序号并扣减权益，再执行受限制的资产转移。状态更新与支出必须置于同一原子状态转换内，或具有经证明等价的并发控制。先放行支出、后异步登记已使用序号，会留下重放或并发重复执行问题。

算法 1 受约束提款的概念执行流程

```
Input: intent x, customer proof, entitlement proof, state s
1  Verify the customer key and the complete intent fields
2  Verify the entitlement and the authenticated ledger state
3  Check domain, chain, vault, expiry and unused sequence
4  Decode and restrict every asset effect of the operation
5  Reject changes that create an unrestricted exit path
6  Atomically:
       consume sequence; deduct entitlement; transfer asset
7  Commit the new state and the execution receipt
Failure: do not transfer protected assets
```

5.3 权益账本与交易状态

权益正确性不能以平台自签证明循环论证。候选实现可以使用客户签署的订单或状态更新，加上可验证的账本状态转移证明；也可以采用具有明确挑战期、数据可用性与诚实观察者假设的争议机制。后者引入新的参与者和时序前提，不能与无需观察者的有效性验证混为一谈。

交易所撮合、杠杆、清算、资金费及手续费会改变客户权益，因此从“客户原始充值余额”直接推出“当前可提余额”并不成立。本文未完成通用交易账本的证明系统。其强安全命题以正确的权益状态为条件，有界检验仅使用固定初始权益，不覆盖真实交易、撮合或清算。若无法实现这一条件，框架只能作为架构要求，不能宣称已保护全部托管资产。

5.4 管理变更与恢复

账户授权根轮换不得仅依靠受胁迫的客服、管理层或平台数据库记录。恢复路径需要预先约定、平台不能单方面伪造的独立凭据。若客户丢失所有独立凭据后仍允许平台立即恢复提款权，就重新引入了平台单方面接管资产的能力；恢复便利性与本文强威胁目标之间存在真实取舍。

治理权限不得直接将存量受保护资产转入普通钱包。对于升级，本文的强部署假设是存量资产的核心退出规则不可由平台治理单方面削弱。若必须升级，可考虑新容器与客户明确选择的迁移；单纯设置升级延迟并不足够，攻击者也可能持续胁迫人员直到延迟结束。需要受保护的独立否决或退出路径，并证明这些路径实际可用。

5.5 冷热调拨与附加权限

资金调拨只有在资产仍留在等价约束容器中、客户权益保持且不存在临时无约束窗口时，才能沿用本文安全论证。将受保护资产先转入平台完全控制的热钱包，再依靠运营纪律管理，已经离开 G 的保护边界。

代币授权、账户委托、任意合约调用和受信任外部合约，均可能改变实际花费能力。EIP-7702 的规范展示了账户授权如何改变账户执行行为[12]。本文不将其作为待修复漏洞，而将“能够授予后续资产控制权的操作”列为需要独立约束的状态改变。默认拒绝此类额外效果，并不等于已经实现所有链的完整效果分析器。

6 条件性安全分析

6.1 强资产守卫路径的授权完整性

命题 1：在 A1 至 A6 成立且所有受保护资产出口均由 G 执行式（3）的前提下，控制交易所业务后端、治理人员、恢复人员及全部平台签名参与者，仍不足以产生未经客户授权或超出真实权益的资产退出。

证明概要采用反证。假设存在首笔违反 P1 或 P2 的成功退出。由 A4，该退出必须经过 G；由 A5，攻击者不能提前取消其检查。若客户授权不真实，则通过 V_U 违反 A1 或 A2；若实际权益不足，则通过 V_L 违反 A3；若交易产生未授权附加效果，则 Effects 或执行正确性假设失效。因此该退出与前提不能同时成立。这是对抽象接受关系的条件性论证，不是对具体合约、链适配器或密码学实现的机器证明。

式（4）将所需性质表示为执行事件的蕴含关系。它对每次资产退出成立，而不是只对系统正常运行时的页面流程成立。

$$\begin{aligned}\mathrm{Execute}(x,s) \Rightarrow \mathrm{Authorized}_U(x)\\ \wedge\ \mathrm{Entitled}_L(x,s) \wedge \mathrm{Unused}(u,n,c,v)\end{aligned} \tag{4}$$

6.2 重放与并发

命题 2：在意图序号域隔离、状态不可回滚且验证与消耗原子的前提下，同一意图最多引起一次成功支出。首个执行消耗对应状态，第二个执行即使携带相同的有效客户签名，也不再满足 Fresh。跨链、跨容器重用必须被式（1）的 c 与 v 拒绝。

该命题不解决链重组、跨链最终性差异或多副本并发实现中的全部问题。实际实现需要规定确认策略、失败交易的序号处理、异常恢复，以及“已签名但未最终确认”的支出状态。有界模型使用单线程原子迁移，不构成并发正确性实验。

6.3 胁迫边界与不可区分性

命题 3：若系统只观察某组主体给出的相同有效授权数据，而攻击者已经控制生成全部必要数据的能力，且不存在剩余独立约束，则该观察者不能仅凭相同数据判断其来自自愿还是胁迫。两次执行对其可见输入相同，确定性验证必然给出相同结果；随机验证也不能凭不存在于输入中的胁迫信息可靠地区分。

因此，本文的强目标依赖将客户授权根、权益正确性及资产规则置于平台内部控制之外，而非要求程序识别人类心理。若客户授权根也被攻击者取得，系统可见的有效授权与正常授权可能一致。金额上限、等待期和异常检测可以限制损失或增加响应机会，但不能自动恢复已经失去的独立授权根。

6.4 签名前控制路径的较弱保证

若无法将 G 落实为实际资产花费条件，可以要求每个签名法定人数中至少有一个独立检查者执行完整验证。在该路径中，保证依赖式（2）、安全的密钥生成和重分享，以及管理恢复对同一限制的保持。它能够改善单点失陷防护，但不能承诺抵御全部签名法定人数同时被控制。本文明确区分这一保证与命题 1，不把二者混用。

7 有界模型检验

7.1 模型与可复现设置

随文程序 model_check.py 使用 Python 标准库实现抽象状态转换及广度优先搜索。初始资金为 2 个抽象单位，Alice 拥有 2 单位真实权益，Mallory 拥有 0 单位。独立授权登记表包含 Alice 的一笔 1 单位提款，以及 Mallory 对自身地址的一笔 1 单位意图；后者具有客户授权，但没有可支出的真实权益。

四个二值能力分别为业务后端控制、平台签名法定人数控制、治理控制和恢复控制，共 16 种组合。签名法定人数控制代表足够数量的参与者失陷，不代表某个普通设备托管人天然具有完整权限。贿赂、胁迫和终端入侵在这里都只映射为能力控制，不模拟现实的物理攻击过程。

每个状态尝试 18 类具体动作，包括原始授权提款、修改接收地址或金额或链、伪造意图、重复提交、伪造权益、直接签名支出、治理绕过、恢复绕过和暂停。搜索深度上限为 5 次迁移。签名不可伪造和权益证明可靠均作为理想谓词处理；程序不实现密码学，不使用真实账号、私钥、资金或交易所接口。

安全观察器独立于候选授权控制逻辑：它将实际输出的支付效果，与固定客户意图登记表、初始真实权益和已观察到的执行次数对照。对无效支付形成终止反例，不将违规支付继续展开。状态数在不同能力组合之间分别累计，不代表全局去重后的不同生产状态。

7.2 检验结果

在 7 个控制配置与各自 16 个能力组合中，共运行 112 个配置，尝试 8,496 次迁移。完整守卫在本文有界范围内未出现授权、权益或单次执行违规；每个控制移除变体均至少出现一类反例。表 2 列出程序实际输出，反例数量表示发生至少一个反例的能力组合数，而非攻击成功概率。

控制配置	出现反例的组合	累计状态数	迁移尝试数
普通账户与平台门限签名	12 / 16	48	864
完整资产守卫	0 / 16	48	864
移除客户意图验证	8 / 16	48	864
移除权益真实性约束	8 / 16	132	2304
移除单次执行约束	16 / 16	48	864
允许治理绕过	8 / 16	80	1440
允许恢复绕过	8 / 16	72	1296

表 2 深度上限为 5 的抽象状态模型检验结果

普通账户基线仍包含正常业务层的客户意图与余额检查。其反例来自业务控制被绕过，或平台签名法定人数直接发起支出；模型没有预设诚实基线无条件允许无余额提款。完整守卫也有正向对照：合法提款确实执行，而非通过拒绝所有交易获得表面安全。

7.3 反例与解释

移除客户意图验证后，受控业务后端可以改变 Alice 的收款地址，而资产守卫无法发现变化。移除权益真实性约束后，攻击者可以先增加 Mallory 的账面权益，再使用 Mallory 的真实授权提款。后者说明“客户签名存在”本身不能保证资产归属正确。

移除单次执行约束后，同一 Alice 意图能够再次执行；模型初始余额足以支付两次，但客户只授权了一次。允许治理绕过或恢复导出无约束控制能力时，攻击者可以先改变控制状态，再直接支出。模型另给出可用性反例：治理暂停能够阻断合法提款，但资产没有因此被转走。

这些结果仅说明小模型能够区分所列控制及旁路。它没有覆盖任意交易次数、多资产组合、真实合约重入、签名库缺陷、侧信道、网络时序、账本证明生成或用户界面欺骗。未发现反例不等于一般性安全证明；其作用是使假设和失败条件可以复现、检查并反驳。

8 部署讨论与研究局限

8.1 托管架构与产品取舍

满足强资产守卫要求，可能使系统接近可验证托管、受约束托管或具有独立退出能力的交易架构。它并非给现有提款接口加一层验证码即可完成。客户授权终端、账户恢复、交易账本证明和各链花费规则都会影响产品、成本与可用性。

全路径约束必须识别运营中实际存在的资金出口。外部清算机构、做市商、借贷、质押、跨链桥及合约授权可能改变资产控制者。若业务需要将客户资产交给不受同等约束的第三方，应明确说明保护边界已经变化，不能继续使用“全部平台人员失陷仍无法盗取”的统一宣传表述。

8.2 代码与制度的剩余信任

程序会执行其实现的规则，但实现可能偏离规范，升级权限可能改变规则，硬件和执行环境也可能失陷。所谓减少人员信任，应落实为更小的可信计算基、可检查的状态转移、客户可验证的授权根以及不能被管理层单方面撤销的资产限制。独立审计能够提供证据，不会把这些前提变为不存在。

本文没有证明某一交易所目前缺少上述控制，也没有量化真实员工受贿或受胁迫的概率。对币安事件的内部入侵路径主要依据当事方初步报告，链上观察不能独立还原全部内部权限。不同交易所之间的风险比较需要更多可验证实现资料。

8.3 后续验证任务

下一阶段应选择一种明确资产与链环境，实现最小守卫和权益状态机，给出权限完整清单，并对部署、升级、暂停、恢复和资产授权进行端到端审计。还需扩展为多笔客户意图、多客户交易和并发执行模型，验证数据不可用、链重组和恶意代币语义下的行为。

在完成这些工作之前，本文应被理解为机制设计与小规模模型检验研究。不得将其描述为“已彻底解决所有信任问题”“已证明任何胁迫下绝对安全”或某家交易所的已验证漏洞披露。

9 结论

员工被收买、托管人员受胁迫和管理层受威胁，都可能使平台内部身份与合法提款意图之间的对应关系失效。减少这类风险的关键，是限制这些主体能够产生的资产效果，而非要求验证程序判断其是否出于自愿。本文以独立客户授权、可验证权益和全路径资产守卫组织这一目标。

条件性分析表明，只有当资产实际花费规则不能被平台签名、治理或恢复权限绕过时，才有可能讨论对全部平台内部授权者失陷的抵抗力。否则保证仍依赖至少一个诚实检查者及其独立控制域。有界检验展示了意图、权益、单次执行及管理恢复约束缺失时的反例，但不替代完整协议实现与生产安全评估。本文将研究目标限定为可验证的授权完整性，并明确保留客户授权根、账本正确性与链上执行等信任假设。

研究声明

研究构想与作者署名为 Koji Tamaki。本文采用 AI 辅助文献检索、论证组织、模型编写和排版；所附模型结果由本项目程序实际运行生成。本文为独立技术研究文本，未经同行评审，不代表所提及机构的立场；未开展真实交易所渗透测试或生产部署。资料核对截至 2026 年 11 月 9 日。

参考文献

[1] BINANCE. 29 October 2026 Binance Security Incident Initial Findings and Response Update[EB/OL]. 2026-11-03 [2026-11-09]. https://www.binance.com/en/blog/community/3229153443759566763

[2] BINANCE. Security Incident Update 2 2026-10-30[EB/OL]. 2026-10-30[2026-11-09]. https://www.binance.com/en-NG/support/announcement/detail/d3306d9dca5243548c813b605e1d1751

[3] TRM LABS. North Korea Steals USD 6.36 Billion From Binance in the Largest Hack in History[EB/OL]. 2026-10-29 [2026-11-09]. https://www.trmlabs.com/resources/blog/north-korea-steals-usd-6-36-billion-from-binance-in-the-largest-hack-in-history

[4] FEDERAL BUREAU OF INVESTIGATION. North Korea Responsible for 6 Billion Plus Binance Attack[EB/OL]. 2026-10-31[2026-11-09]. https://www.fbi.gov/investigate/cyber/alerts/2026/north-korea-responsible-for-6-billion-binance-attack

[5] OKX. Protecting your assets[EB/OL]. [2026-11-09]. https://www.okx.com/wallet-security

[6] CONNOLLY D, KOMLO C, GOLDBERG I, et al. The Flexible Round-Optimized Schnorr Threshold FROST Protocol for Two-Round Schnorr Signatures[S]. RFC 9591, 2024. https://www.rfc-editor.org/rfc/rfc9591.html

[7] SALTZER J H, SCHROEDER M D. The protection of information in computer systems[J]. Proceedings of the IEEE, 1975, 63(9): 1278-1308. DOI: 10.1109/PROC.1975.9939. https://web.mit.edu/Saltzer/www/publications/protection/

[8] JOINT TASK FORCE. Security and Privacy Controls for Information Systems and Organizations[S]. NIST SP 800-53 Rev. 5, 2020. https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final

[9] BARKER E. Recommendation for Key Management Part 1 General[S]. NIST SP 800-57 Part 1 Rev. 5, 2020. https://csrc.nist.gov/pubs/sp/800/57/pt1/r5/final

[10] SYED T A, KHAN A A, AKRAMA A. Intent-Bound Authorization for Cryptocurrency Withdrawals Under Backend Compromise[EB/OL]. arXiv:2611.00839v1, 2026[2026-11-09]. https://arxiv.org/abs/2611.00839

[11] DAGHER G G, BUENZ B, BONNEAU J, et al. Provisions Privacy-preserving proofs of solvency for Bitcoin exchanges[R]. Cryptology ePrint Archive, Paper 2015/1008, 2015. https://eprint.iacr.org/2015/1008

[12] BUTERIN V, WILSON S, DIETRICHS A, et al. EIP-7702 Set Code for EOAs[S/OL]. 2024[2026-11-09]. https://eips.ethereum.org/EIPS/eip-7702

附录 A 复现与模型边界

在 Python 3.10 或更高版本中，从项目目录运行 python model_check.py。程序仅使用标准库，并写出 model_results.json。重新运行应得到 112 个配置和 8,496 次迁移尝试。详细结果包含每个能力组合、首个最短反例、模型参数及脚本 SHA-256，可用于核对本文表 2。

7 个配置的差异分别位于资产出口是否受约束、是否校验客户意图、是否校验权益真实性、是否执行单次序号、治理是否能够绕过、恢复是否能够建立无约束出口。没有为真实交易所设置攻击目标，也没有处理真实密钥。任何进一步扩展都应重新生成结果，并同步更新摘要、表 2 和本附录，不能沿用旧的计数。

附录 B 术语对照

中文术语	英文术语	本文含义
授权完整性	authorization integrity	实际资产效果与独立授权一致
内部人员威胁	insider threat	具有内部身份的主体滥用能力
胁迫	coercion	主体受威胁后按攻击者要求行动
合谋	collusion	多个主体协同突破控制边界
签名法定人数	signing quorum	足以共同生成平台签名的参与者集合
独立用户意图	independent customer intent	不由平台单方面伪造的客户授权
权益账本	entitlement ledger	经合法状态转换形成的可提权益
资产守卫	asset guard	对实际资产花费具有强制力的验证规则
完全仲裁	complete mediation	每次受保护访问均经过授权检查
有界模型检验	bounded model checking	在声明的有限状态与深度内搜索反例